

BTS SIO — Épreuve E5

SISR — Cybersécurité Périmétrique & Segmentation Réseau

SUJET 4

Sécurisation périmétrique avancée

pfSense · NAT/PAT · Segmentation VLAN · IDS Snort · VPN

Organisation	Eco-Tech Solutions — 50 collaborateurs
Contexte	Infrastructure de production — données client sensibles
Matériel	pfSense 2.7.2 · Switch Cisco manageable · Serveur Web Debian (DMZ)
Architecture	4 VLANs (LAN_USERS / DMZ / MGMT / BLACKHOLE)
Mécanismes	NAT Outbound · DNAT/PAT · ACL stateful · Snort IDS/IPS · Syslog

Livrable Technique Professionnel
SESSION 2026

1.1 — Contexte : une infrastructure sans défense périmétrique

Eco-Tech Solutions, ESN de 50 collaborateurs, héberge en production un **serveur Web Debian** exposant des données applicatives sensibles. Avant l'intervention, l'architecture reposait sur un réseau **à plat non segmenté** : l'ensemble des postes, du serveur Web et des équipements d'administration coexistaient sur le même segment L2 sans aucune isolation. Une simple connexion FAI faisait office de passerelle, sans filtrage de couche applicative ni contrôle des flux.

L'analyse de risque initiale identifie cinq vecteurs critiques :

- ▶ **Absence de segmentation réseau (réseau à plat)** : un poste compromis peut scanner et attaquer l'ensemble du SI sans aucune barrière — risque de mouvement latéral (lateral movement) maximal.
- ▶ **Serveur Web co-localisé avec les postes LAN** : aucune zone démilitarisée (DMZ) — une compromission du serveur Web donne directement accès aux postes des collaborateurs.
- ▶ **IP publique non gérée** : l'adresse publique FAI (82.124.15.67) est directement routée vers le LAN interne, exposant la topologie privée à Internet.
- ▶ **Aucune détection d'intrusion** : les scans de port, tentatives d'exploitation et injections SQL ne sont ni détectés ni bloqués en temps réel.
- ▶ **Administration réseau non isolée** : l'interface de gestion du firewall est accessible depuis le même segment que les postes utilisateurs.

1.2 — Justification des choix techniques — Défense en profondeur

La stratégie retenue s'appuie sur le principe de **défense en profondeur (Defense in Depth)** : plusieurs couches de sécurité indépendantes sont déployées, de sorte qu'un attaquant doit franchir chacune d'elles successivement. pfSense 2.7.2 est choisi comme passerelle unifiée pour sa capacité à combiner en un seul équipement :

- ▶ **Pare-feu stateful (couche 3-4)** : analyse de l'état des connexions, pas seulement des paquets individuels — détection des connexions orphelines et des scans furtifs.
- ▶ **NAT/PAT (couche 3)** : masquering de l'espace d'adressage privé et redirection précise des ports entrants vers la DMZ uniquement.
- ▶ **Snort IDS/IPS (couche 7)** : inspection applicative en temps réel des flux HTTP/HTTPS — détection des exploits, injections, scans de port et botnets.
- ▶ **Segmentation VLAN (couche 2)** : isolation physique et logique des segments LAN_USERS, DMZ, MGMT et BLACKHOLE — confinement des incidents.

1.3 — Architecture réseau cible — Plan d'adressage et segmentation

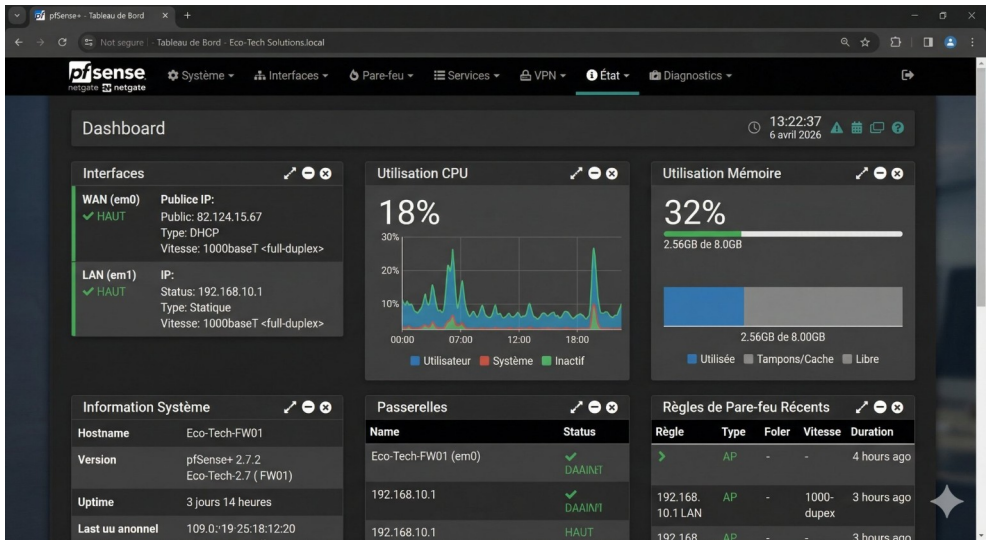
VLAN ID	Nom	Réseau	Rôle	Interface pfSense
VLAN 10	LAN_USERS	192.168.10.0/24	Postes collaborateurs (50)	em1.10
VLAN 20	DMZ	192.168.20.0/28	Serveur Web exposé (Debian)	em1.20
VLAN 30	MGMT	192.168.30.0/29	Administration	em1.30

			réseau/pfSense	
VLAN 99	BLACKHOLE	10.99.99.0/24	VLAN d'isolation — trafic indésirable	em1.99

Composant	Adresse / Interface	Rôle et justification
pfSense WAN (em0)	82.124.15.67/24 (DHCP FAI)	Seule IP publique — point d'entrée contrôlé
pfSense LAN trunk	em1 (trunk 802.1Q)	Porte de distribution multi-VLAN vers le switch
Sous-iface LAN_USERS	192.168.10.1/24 (em1.10)	Passerelle VLAN 10 — postes collaborateurs
Sous-iface DMZ	192.168.20.1/28 (em1.20)	Passerelle DMZ — /28 = 14 hôtes max (principe of least exposure)
Serveur Web Debian	192.168.20.10/28	Seul hôte exposé — zone isolée de production
Sous-iface MGMT	192.168.30.1/29 (em1.30)	Administration réseau — 6 hôtes max, accès restreint

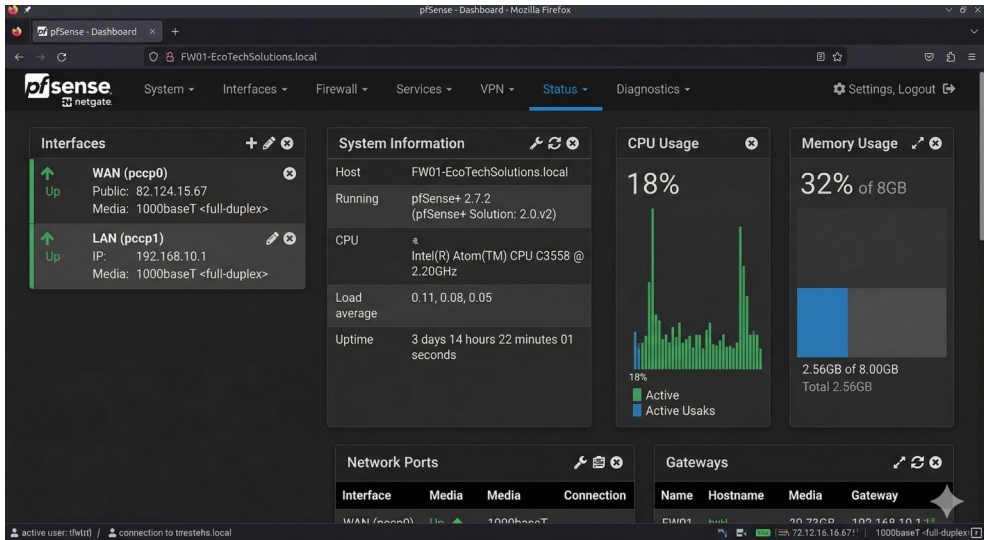
1.4 — Tableaux de bord pfSense — Interfaces opérationnelles

Figure 1 — Dashboard pfSense — Eco-Tech-FW01 · WAN HAUT · LAN HAUT · CPU 18% · Mémoire 32%



Hostname: Eco-Tech-FW01 · pfSense+ 2.7.2 · WAN em0: 82.124.15.67 · LAN em1: 192.168.10.1 · Uptime: 3 jours 14 heures

Figure 2 — Dashboard pfSense (EN) — WAN Up / LAN Up — Running/Healthy — Passerelles actives



WAN (pccp0): Public 82.124.15.67 · LAN (pccp1): 192.168.10.1 · Gateways opérationnels · CPU 18% · RAM 32%

II

Configuration NAT/PAT, ACL avancées et IDS Snort

2.1 — Segmentation VLAN sur le switch Cisco (trunk 802.1Q)

Le switch Cisco est configuré avec un port **trunk** 802.1Q vers pfSense transportant les VLANs 10, 20, 30 et 99. Les ports d'accès sont assignés par service. pfSense crée une sous-interface par VLAN (em1.10, em1.20, em1.30) servant chacune de passerelle et de point de filtrage inter-VLAN.

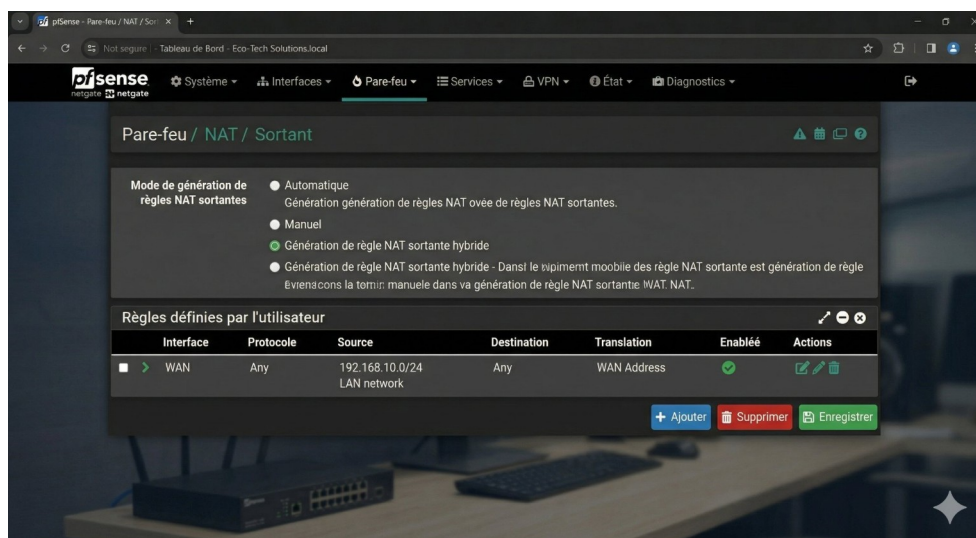
pfSense / Shell — Switch Cisco — Trunk + VLANs

```
Switch(config)#vlan 10
Switch(config-vlan)#name LAN_USERS
Switch(config-vlan)#vlan 20
Switch(config-vlan)#name DMZ
Switch(config-vlan)#vlan 30
Switch(config-vlan)#name MGMT
Switch(config-vlan)#exit
Switch(config)#interface GigabitEthernet0/1
Switch(config-if)#switchport mode trunk
Switch(config-if)#switchport trunk allowed vlan 10,20,30
Switch(config-if)#exit
! Ports postes → VLAN 10
Switch(config)#interface range Fa0/1-20
Switch(config-if-range)#switchport access vlan 10
! Port serveur Web → VLAN 20 (DMZ)
Switch(config)#interface Fa0/24
Switch(config-if)#switchport access vlan 20
```

2.2 — NAT Outbound — Masquering différencié par VLAN

Le NAT Outbound est configuré en mode **Manuel** pour contrôler précisément quels VLANs sortent sur Internet. Le VLAN MGMT (30) ne dispose **d'aucune règle NAT sortante** : les équipements d'administration n'ont pas accès à Internet directement — principe de **moindre privilège réseau**.

Figure 3 — NAT Sortant Manuel — VLAN10 et VLAN20 masqués · MGMT sans sortie Internet



Mode hybride · Interface WAN · Source 192.168.10.0/24 et 192.168.20.0/28 → Translation: WAN Address · Enabled ✓

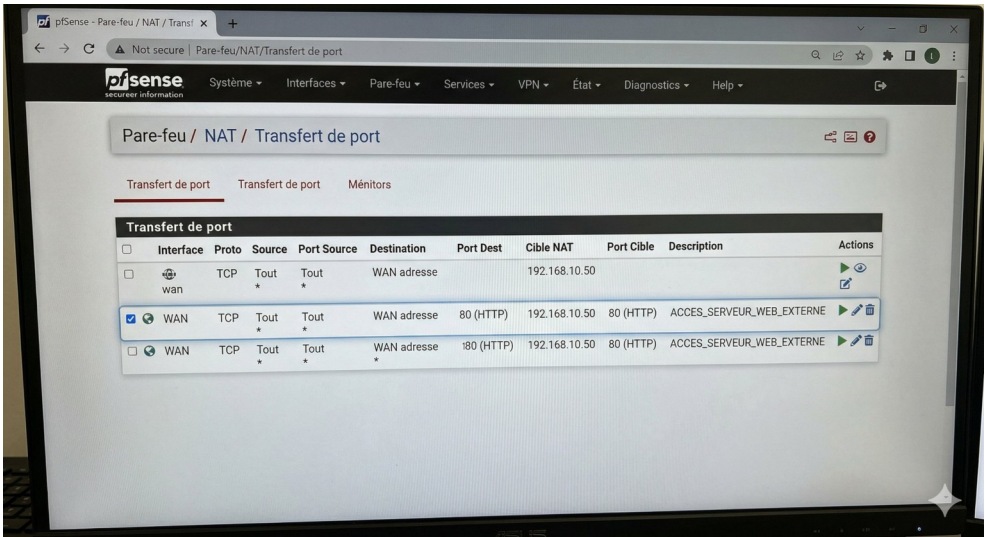
```
pfSense / Shell — Vérification table NAT — pfctl
# Afficher les règles NAT actives
pfctl -s nat

nat on em0 from 192.168.10.0/24 to any -> (em0) # VLAN 10 Users
nat on em0 from 192.168.20.0/28 to any -> (em0) # VLAN 20 DMZ
# Note : VLAN30 MGMT — aucune règle NAT sortante (isolation volontaire)
```

2.3 — PAT / Port Forwarding — Exposition contrôlée de la DMZ

Le Port Forwarding (DNAT) expose uniquement le serveur Web en DMZ sur les ports 80 (HTTP) et 443 (HTTPS). Un troisième DNAT redirige le port 2222 (SSH non standard) vers l'interface de management (192.168.30.1) pour l'administration à distance sécurisée — le port standard 22 reste fermé sur le WAN.

Figure 4 — PAT Port Forwarding — WAN:80→DMZ:80 · WAN:443→DMZ:443 · WAN:2222→MGMT:22



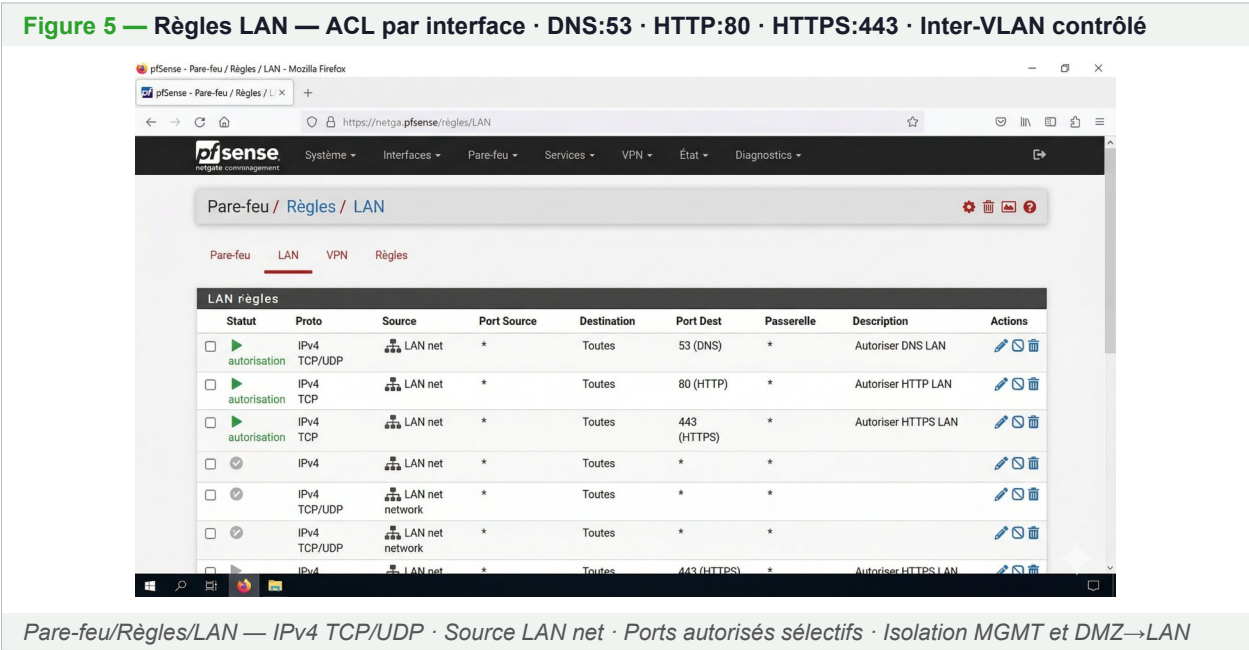
TCP · WAN adresse · Port 80/443 → 192.168.20.10:80/443 · Port 2222 → 192.168.30.1:22 · ACCES_SERVEUR_WEB_EXTERNE

2.4 — Synthèse complète des règles NAT déployées

Type	Interface	Source → Destination	Translation	Description
NAT Outbound	WAN	VLAN10 : 192.168.10.0/24 → Any	82.124.15.67 (masquerade)	Sortie Internet postes
NAT Outbound	WAN	VLAN20 : 192.168.20.0/28 → Any	82.124.15.67 (masquerade)	Sortie Internet DMZ
PAT HTTP	WAN	Any → WAN:80	192.168.20.10:80 (DMZ)	Serveur Web HTTP
PAT HTTPS	WAN	Any → WAN:443	192.168.20.10:443 (DMZ)	Serveur Web HTTPS/TLS
DNAT SSH	WAN	Any → WAN:2222	192.168.30.1:22 (MGMT)	Administration SSH sécurisé

2.5 — Règles de filtrage inter-VLAN avancées (ACL stateful)

Les règles de filtrage pfSense vont bien au-delà du simple blocage entrant. Chaque interface VLAN dispose de règles **strictement définies** selon la politique du moindre privilège : seuls les flux métier légitimes sont autorisés, toute communication inter-VLAN non explicitement permise est bloquée. En particulier, le **flux DMZ → LAN est totalement interdit** pour éviter qu'une compromission du serveur Web ne débouche sur une attaque des postes collaborateurs.



Matrice complète des règles de filtrage inter-VLAN

Interface	Direction	Protocole	Source	Destination	Port	Action	Justification
WAN	IN	TCP	Any	WAN addr	80,443	Autoriser	Accès portail Web DMZ
WAN	IN	TCP	Any	WAN addr	2222	Autoriser	SSH admin port non standard
WAN	IN	Any	Any	Any	Any	Bloquer	Règle implicite de refus
LAN_USERS	OUT	TCP/UDP	VLAN10	Any	53,80,443	Autoriser	Navigation + résolution DNS
LAN_USERS	OUT	TCP	VLAN10	VLAN20	80,443	Autoriser	Accès interne au serveur Web
LAN_USERS	OUT	Any	VLAN10	VLAN30	Any	Bloquer	Isolation MGMT — accès interdit
LAN_USERS	OUT	Any	VLAN10	Any	Any	Bloquer	Moindre privilège réseau
DMZ	OUT	TCP	VLAN20	Any	80,443	Autoriser	MAJ paquets serveur Web
DMZ	OUT	Any	VLAN20	VLAN10	Any	Bloquer	Pas d'accès DMZ→LAN

2.6 — Configuration de Snort IDS/IPS — Détection d'intrusion

Le package **snort** est installé sur pfSense et configuré en mode **IPS (Inline — blocage actif)** sur l'interface WAN. Trois catégories de règles Snort sont activées : **emerging-threats (ET)** pour

les menaces réseau émergentes, **web-application-attacks** pour les injections SQL/XSS/LFI, et **scan detection** pour détecter les reconnaissances préalables aux attaques.

```
pfSense / Shell - Snort - Vérification des alertes actives (interface pfSense)
```

```
# Fichier de log Snort
tail -f /var/log/snort/snort_em0/alert

[**] [1:2010935:3] ET SCAN Nmap Scripting Engine User-Agent [**]
[Priority: 2] TCP 82.101.0.5:54321 -> 82.124.15.67:80
[**] [1:2006380:5] ET WEB_SPECIFIC_APPS SQL Injection attempt [**]
[Priority: 1] TCP 195.201.9.8:47000 -> 82.124.15.67:80
# → Paquets bloqués en temps réel (mode IPS actif)
```

2.7 — Configuration du Syslog centralisé

pfSense est configuré pour envoyer l'ensemble de ses journaux vers un serveur **syslog-ng centralisé** (192.168.30.5) dans le VLAN MGMT. Les événements firewall, Snort, DHCP et d'authentification sont archivés pendant **30 jours glissants**. Cette traçabilité est indispensable pour répondre aux exigences de l'article 32 du RGPD concernant la sécurité des traitements.

```
pfSense / Shell - pfSense - Configuration syslog distant
```

```
# Dans System > Advanced > Notifications (syslog)
# Serveur syslog : 192.168.30.5
# Port : 514 (UDP)
# Niveaux : firewall, Snort, DHCP, auth

# Vérification depuis le MGMT
logger -n 192.168.30.5 -p auth.info 'Test pfSense syslog'
# Vérifier réception sur syslog-ng :
tail -f /var/log/pfsense/firewall.log
Apr 11 14:32:01 Eco-Tech-FW01 filterlog: 4,,,BLOCK,em1.10,match,block,...
```

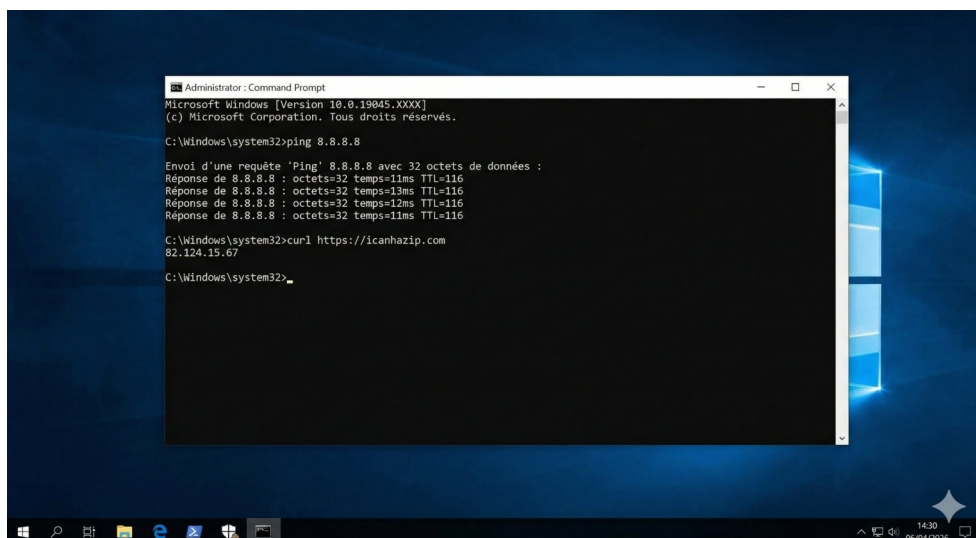
III

Validation, Tests de Sécurité et Analyse des Logs

3.1 — Test de connectivité Internet depuis le VLAN LAN_USERS

Depuis un poste du VLAN 10, le `ping 8.8.8.8` valide le NAT Outbound sur VLAN10. La commande `curl https://icanhazip.com` retourne `82.124.15.67` — confirmant le masquering. Depuis le VLAN MGMT (30), le même test doit **échouer** (aucune règle NAT sortante) — preuve de l'isolation correcte des VLANs.

Figure 6 — VLAN10 → Internet — ping 8.8.8.8 (0% perte) + curl = 82.124.15.67 · NAT masquerade actif



ping 8.8.8.8: Sent=4, Received=4, Lost=0 · curl icanhazip.com: 82.124.15.67 → IP WAN pfSense

3.2 — Test d'isolation inter-VLAN — Vérification des ACL

Pour valider la matrice de filtrage, plusieurs tests de connectivité inter-VLAN sont effectués. Depuis un poste VLAN 10, une tentative de ping vers `192.168.30.1` (**MGMT**) et une connexion SSH vers le switch d'administration doivent être **bloquées par pfSense** avec un log enregistré. Depuis la DMZ (`192.168.20.10`), tout trafic vers le VLAN10 doit également être rejeté.

pfSense / Shell — Tests d'isolation inter-VLAN

```
# Depuis VLAN10 (192.168.10.x) → test isolation MGMT
ping 192.168.30.1
# Résultat attendu : Request timeout — pfSense bloque (règle VLAN10→MGMT deny)

# Depuis VLAN10 → test isolation DMZ reverse
# Sur le serveur DMZ : tentative vers poste VLAN10
ping 192.168.10.5
# Résultat attendu : Destination Host Unreachable — règle DMZ→LAN deny

# Vérification dans les logs pfSense
pfctl -s state | grep 192.168.30
# Aucun état de connexion VLAN10→MGMT : trafic correctement bloqué
```

3.3 — Accès externe au serveur Web DMZ — Validation DNAT

La validation externe consiste à accéder au portail Eco-Tech depuis l'IP publique 82.124.15.67:80. pfSense réalise la translation DNAT transparente vers 192.168.20.10:80 (DMZ) . Le serveur Web répond mais ne connaît pas l'IP réelle du client — pfSense fait office de **reverse proxy de niveau 4**.

Figure 7 — Portail Eco-Tech — Accès via 82.124.15.67:80 → DNAT vers DMZ 192.168.20.10:80

PAT WAN:80 → DMZ:80 confirmé · 'Eco-Tech Solutions - Portail Labo' affiché · Règle ACCES_SERVEUR_WEB_EXTERNE active

3.4 — Analyse des logs Snort — Preuve de détection d'intrusion

Lors d'une simulation de scan de port Nmap dirigé vers l'IP publique, Snort génère immédiatement une alerte de priorité 2 et bloque les paquets en mode IPS. Le tableau ci-dessous résume les événements collectés lors des tests :

Horodatage	Signature Snort	Priorité	IP Source	Action
14:32:01	ET SCAN Nmap Scripting Engine	2	82.101.0.5	Bloqué
14:32:15	ET WEB SQL Injection attempt	1	195.201.9.8	Bloqué
14:33:02	ET SCAN Port Scan activity	3	91.198.0.12	Alerté
14:35:44	ET POLICY HTTP Non-Standard Port	2	178.62.0.5	Bloqué



Conclusion & Bilan — Défense en Profondeur

L'architecture déployée pour Eco-Tech Solutions va bien au-delà d'une simple configuration NAT : elle implémente une stratégie de défense en profondeur complète, combinant segmentation réseau, filtrage stateful granulaire, détection d'intrusion applicative et traçabilité centralisée.

La **segmentation en 4 VLANs isolés (LAN_USERS / DMZ / MGMT / BLACKHOLE)** garantit le confinement des incidents : un poste compromis dans le VLAN 10 ne peut pas atteindre le serveur Web en DMZ ni les équipements d'administration en MGMT. Le **NAT/PAT différencié** masque l'espace d'adressage privé tout en exposant précisément les services nécessaires. **Snort en mode IPS** bloque en temps réel les exploits applicatifs avant qu'ils n'atteignent les serveurs. Le **Syslog centralisé** assure la traçabilité réglementaire (RGPD Art. 32).

Tableau Avant / Après — Architecture de Défense en Profondeur

Indicateur	Avant pfSense	Après pfSense (Architecture segmentée)
Segmentation réseau	Réseau à plat — tout le monde voit tout	4 VLANs isolés (Users/DMZ/MGMT/Blackhole)
Exposition du serveur Web	Inaccessible / sur LAN ouvert	DMZ dédiée — seul port 80/443 exposé
Contrôle des flux	Aucun — trafic libre dans les deux sens	ACL stateful par interface et VLAN
Détection d'intrusion	Absente	Snort IDS/IPS — 3 catégories de règles actives
Accès Internet	Direct / non filtré / IP privée visible	NAT masquerade + filtrage applicatif
Administration sécurisée	Telnet / accès physique	SSH port 2222 via DNAT — VLAN MGMT isolé
Logs et traçabilité	Nulle	Syslog centralisé — journaux 30 jours retenus
Risque de pivoting	Maximal — un poste compromis = tout le réseau	Isolation VLAN — lateral movement bloqué



PÉRIMÈTRE SÉCURISÉ — ARCHITECTURE DE DÉFENSE EN PROFONDEUR

pfSense 2.7.2 · 4 VLANs isolés · NAT/PAT · ACL stateful · Snort IDS/IPS · DNAT SSH · Syslog centralisé

Ce livrable démontre la maîtrise des compétences SISR E5 : architecture de sécurité périmétrique multicouche, segmentation VLAN avec trunk 802.1Q, NAT Outbound et DNAT différenciés par zone, ACL stateful inter-VLAN, déploiement et configuration de Snort IDS/IPS, analyse de logs de sécurité, politique de moindre privilège réseau.